LAB 4

Siddeshwarprasad K R

1RUA24CSE0454

Aim

To conduct a structured tabletop exercise simulating a social engineering (phishing) attack and evaluate the organization's incident response, coordination, and decision-making process.

Inputs

- Simulated phishing attack scenario
- Defined response team roles
- Organizational communication structure

Tools Used

- Whiteboard / Shared documentation platform
- Sample phishing email
- Incident response guidelines

Dataset Required

- Sample phishing email containing:
    - Spoofed sender address
    - Urgent call-to-action message
    - Malicious link or attachment
    - Indicators of compromise (IOCs)

Brief Theory

A tabletop exercise is a discussion-based cybersecurity simulation that allows organizations to test their preparedness without affecting live systems.

Social engineering attacks manipulate human behavior rather than exploiting technical vulnerabilities. Phishing emails deceive users into revealing confidential information, clicking malicious links, or downloading harmful files.

These exercises help organizations:

- Validate incident response procedures
- Improve inter-department coordination
- Identify weaknesses in awareness and communication
- Enhance readiness for real-world cyber incidents

Procedure

Role Assignment

Participants were assigned roles to simulate a real incident response environment:

Role	Responsibility
SOC (Security Operations Center)	Detect and analyze the phishing attack
IT Team	Implement containment and technical mitigation
HR Department	Communicate with employees and track awareness
Management	Approve decisions and ensure operational continuity
Incident Coordinator	Oversee and document the response process

Scenario Presentation

A phishing email scenario was introduced:

Employees received an email claiming to be from the Finance Department requesting urgent login verification to avoid payroll suspension.

Suspicious indicators included:

- Slightly modified sender domain
- Urgent language creating pressure
- External link requesting credentials
- Unexpected request for sensitive information

Detection Phase

The SOC team discussed detection methods:

- Email filtering system flagged the message
- Employees reported suspicious email
- Domain and header analysis revealed spoofing
- URL identified as malicious

Response Actions

SOC Team

- Investigated email origin and indicators
- Classified incident severity
- Identified impacted users

IT Team

- Blocked malicious domain and URLs
- Isolated affected systems
- Forced password resets

HR Department

- Notified employees about phishing attempt
- Advised users not to interact with email
- Coordinated awareness communication

Management

- Approved containment actions
- Ensured business operations continued
- Reviewed escalation process

Containment Measures

- Removed phishing email from all inboxes
- Blocked sender at email gateway
- Monitored systems for unauthorized access
- Conducted security scans

Recovery Phase

- Restored secure access to affected accounts
- Verified no data breach occurred
- Returned systems to normal operation

Gap Analysis

The exercise revealed several improvement areas:

- Limited employee awareness of phishing indicators
- Lack of a formal phishing reporting channel
- Delays in cross-team communication
- Need for stronger email security configuration

Recommended Improvements

- Conduct regular cybersecurity awareness training
- Implement phishing simulation programs
- Introduce a one-click phishing reporting system
- Strengthen email filtering and authentication controls
- Update incident response playbook with defined escalation paths

Conclusion

The tabletop exercise effectively simulated a real-world social engineering attack and demonstrated the importance of preparedness, communication, and clearly defined responsibilities. The activity helped identify procedural weaknesses and provided actionable improvements to enhance the organization's incident response capability.

Tabletop exercises are a critical component of proactive cybersecurity strategy, enabling organizations to respond confidently and efficiently to emerging threats.